On The Shift to Decentralised Identity Management in Distributed Data Exchange Systems

Mariia Bakhtina, Raimundas Matulevičius, Ahmed Awad
Institute of Computer Science, University of Tartu
Tartu, Estonia
{mariia.bakhtina,rma,ahmed.awad}@ut.ee

Petteri Kivimäki
Nordic Institute for Interoperability Solutions
Finland
petteri.kivimaki@niis.org

ABSTRACT

The commonly used centralised trust and centralised identity management make information systems and organisations prone to a single point of failure. Therefore, decentralised identity management has appeared as an alternative solution to mitigate the weaknesses of centralised identity. In this paper, we propose an approach of system analysis that should guide organisations that considers the transition to decentralised identity management. The approach aims to support decision-making about the usefulness of the transition based on the created assessment model. The approach is validated through a case study of the X-Road ecosystem.

CCS CONCEPTS

• **Software and its engineering → Software system structures**; • **General and reference → Design**; • **Security and privacy → Authentication**.

KEYWORDS

Trust, Decentralised Identity, Identity Management, System Design

ACM Reference Format:
Mariia Bakhtina, Raimundas Matulevičius, Ahmed Awad and Petteri Kivimäki. 2023. On The Shift to Decentralised Identity Management in Distributed Data Exchange Systems. In *The 38th ACM/SIGAPP Symposium on Applied Computing (SAC '23), March 27-March 31, 2023, Tallinn, Estonia.* ACM, New York, NY, USA, Article 4, 10 pages. https://doi.org/10.1145/3555776.3577678

1 INTRODUCTION

Enabled by rapid digitisation, organisations strive to benefit from collaborative work to get a competitive advantage by delivering unique products. Businesses create supply chains to deliver products and services. Governmental agencies collaborate to provide services that help the nation's well-being. What unites them is a business need for communication with external entities. Organisations need to know with which entities they exchange information, and to be sure that the communicating party is the one it claims to be. In turn, communication between organisations per se and their information systems (ISs) requires trust.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than ACM must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.
SAC '23, March 27-March 31, 2023, Tallinn, Estonia
© 2023 Association for Computing Machinery.
ACM ISBN 978-1-4503-9517-5/23/03…$15.00
https://doi.org/10.1145/3555776.3577678

Trust is one of the key concepts around which businesses and security are formed. Mayer *et al.* [15] define trust as "the willingness of a party to be vulnerable to the actions of another party, based on the expectation that the other party will perform a particular action important to the trustor, irrespective of the ability to monitor or control that other party". A root of trust (RoT) is an axiomatically accepted point to be trusted. The commonly used centralised RoT assumes that organisations choose to trust a third-party centralised authority. A trusted authority is expected to enable assurance of IS security by issuing and managing credentials. The authority declares which entities can be trusted, and organisations rely on the accreditation of the authority's staff. The ISs security heavily depends on the cryptography that is built over the RoT. As a result, organisations that use ISs that are based on the centralised RoT are prone to a single point of failure.

Recent work [2, 16, 20] has focused on developing an alternative to the centralised RoT – the self-sovereign identity (SSI) ecosystem. Self-sovereign identities are decentralised due to the algorithmic RoT and do not rely on a single provider for storing and managing the identity's data. The algorithmic RoT is founded on the trust in the cryptographic mechanisms and the algorithms' correctness in the ISs. However, while the research community is advocating the advantages of the shift towards SSI and decentralised identities, they do not provide guidelines on how to assess the improvements enabled by the transition, how it will influence business operations or how to plan such a transition. Therefore, in this paper, we research the transition to the decentralised IdM system in the data exchange system called X-Road.

X-Road© is an open-source solution that acts as a data exchange layer between ISs that enables organisations (i.e. Members) to communicate securely. X-Road serves as the backbone of the Estonian, Icelandic, and Finnish (and a few other countries) digital government infrastructures. Currently, X-Road relies on a centralised root of trust and centralised identity management (IdM). Except for the proneness to a single point of failure, the problem of the existing solution is the lengthiness of the new Members' onboarding which relies on the Members' identity set-up and may take from a few hours to months.

The purpose of our research is to investigate how the transition from centralised to decentralised identity management should be approached by the organisation and what are the effects of such transition on the member management process. By the member management process we mean new member's onboarding to the system (incl. identity issuance and verification), access control through the identity verification, member's offboarding (incl. credentials

revocation). The research question (RQ) is *how can the shift to decentralised identity management affect trust and member management in the data exchange systems?* Specifically, we aim to validate the following hypotheses: (i) centralised IdM is the root cause of the delays in the member onboarding process, and (ii) the decentralised approach for IdM in X-Road could help to improve the situation with member management without harming the social trust.

The paper's contribution is a proposed approach to the system analysis that should guide organisations that consider the IdM system transition. The approach aims to support decision-making about the usefulness of the transition based on the created assessment model. The validation is conducted through the case study of the X-Road system ecosystem. The case study presents system analysis and design results through enterprise modelling from the perspectives of actors' dependencies, processes, resources, and trust. Additionally, the case study compares how well the IdM systems support social trust and trustors' expectations (i.e. how trustworthy they are). This work-in-progress paper presents the results of the applied exploratory research that aims to prove the feasibility of SSI implementation and its usefulness in the context of running data exchange systems, namely X-Road.

2 BACKGROUND

2.1 Identity Management and Verifiable Credentials

Digital identity is "a set of claims made by one digital subject about itself or another digital subject" [5]. *Identity management (IdM)* refers to the set of policies and technologies used to ensure that the resource users are eligible to access them based on their identity characteristics. The IdM operations include identification and verification, which rely on the usage of credentials.

Verifiable credential (VC) is "any (tamper-resistant) set of information that some authority (issuer) claims to be true about the subject of the credential and which enables the subject to convince others (who trust that authority) of these truths" [20]. Commonly, the subject of the VC is its holder. VCs are used as a baseline for providing the verifier with proof about the VC's subject. Except for the proof of some statement about the VC's subject, the verifier must be able to determine the following from the presented VCs: (i) who issued the credential; (ii) VC has not been tampered with since it was issued; (iii) VC has not expired or been revoked. Verifiable Credentials Data Model v1.1 [26] is an open standard of digital credentials format that ensures that credentials are cryptographically secure, privacy-respecting, and machine-verifiable.

While different documents can play the role of verifiable credentials, each VC is characterised by an identifier. Such identifiers have been based on the public key infrastructure (PKI), where certificates are VCs issued by centralised certification authorities. With the emergence of self-sovereign identity (SSI), the idea of removing a centrally governed authority is getting its popularity as it allows removing a single point of failure and potentially bringing automation to the issuance of the credentials.

2.2 Conventional Public Key Infrastructure

Public Key Infrastructure using X.509 (PKIX) is the most used conventional PKI implementation [22]. In the case of conventional PKI, there should be a root authority that accredits trusted third-party certification authorities (CAs). Additionally, each CA holds a (centralised) certificate registry. CAs follow X.509 standard [4] for issuing digital certificates by publicly trusted Certification Authorities. However, while the whole infrastructure is based on the CA's trust, compromising it or its registry of certificated negates the whole trust model. From the technical point of view, using a set of trusted certification authorities puts obligations on integration with each CA's system to verify credentials.

2.3 Decentralised Public Key Infrastructure

The main advantages of the decentralised PKI are based on decentralised identifiers (DIDs), which are permanent, resolvable, and cryptographically verifiable. Unlike X.509 certificate trees that rely on centralised registries under the control of a single authority, DIDs must help avoid single points of failure by using decentralised networks (i.e. verifiable data registry) for storage. A *verifiable data registry* (VDR) is commonly implemented using distributed ledger technology (DLT). Such a DLT can be presented by general-purpose public blockchain networks or special-purpose distributed ledger networks. In principle, VDR can be implemented as distributed file systems (e.g., IPFS), key event logs (e.g., KERI), and distributed hash tables, but in this paper, we focus only on VDRs based on DLT.

A Decentralised Identifier (DID) identifies the subject. The DID subject can be a human, organisation or any resource that should be identified. An entity that has the capability to change the information associated with a DID and use it in a VC is called a *DID controller*. DID controller and DID subject may or may not be the same entities. *DID document* is an artefact of DID resolution controlled by the DID controller that is used to describe the DID subject [20]. A DID document itself is not a resource, therefore, it does not have a separate resource identifier. *Resolution* of DID refers to the transformation of the given DID to a DID document using the defined DID method. Regardless of the nature of the subject, DID document is dynamically constructed by the *DID resolver* based on the provided DID and the transactions connected to this DID in the VDR. DIDs are globally unique, and no central authority manages them. The controller creates the DID on its own and has complete control over the data that can be accessed using the identifier.

Digital wallet stores the holder's credentials. A *digital agent* is a software that enables the VC holder to operate their digital wallet. Additionally, digital agents establish secure connections with other agents to exchange credentials and DIDs. Commonly, the digital wallet is a part of a digital agent that enables secure storage of credentials. While digital agents may vary by their type (mobile and cloud), the interoperability on the client layer allows holders to select the preferred agent regardless of which agents are used by other entities or which registry is used for storing credentials. Finally, a digital agent allows the VC holder to define *Verifiable Presentations* (VP). VP is a data artefact containing data from one or more VCs shared with a verifier. VP may allow a holder to present a claim in a synthesized form instead of the original VC (e.g., through zero-knowledge proofs) to preserve the holder's privacy.

2.4 Related Work

Recent studies investigated decentralised identity management from different perspectives. In [7], the authors demonstrated how BCT could help in the healthcare sector with audibility. They also conclude that blockchain-enabled business processes and IdM can help to protect patients' privacy and provide more robust mechanisms for establishing digital identities compared with centralised or federated architectures. However, the research mainly focuses on BCT's advantages for federated learning. ENISA [1] also acknowledges that SSI is an effective way of managing digital identities and assuring data protection. Besides, they highlight the need for parallel existence of SSI with other more established identification methods like x.509 PKI. Liu *et al.* [14] showed that the main differences between centralised and DLT-based IdM are stemming from the trust model and data storage. Maintaining privacy requirements and implementing certain identity operations such as deletion in a decentralised identity system is more complicated. Having a similar focus, our paper studies how decentralised IdM and blockchain support trust within business processes in the data exchange system in the context of the governmental sector.

Grüner *et al.* [10] proposed a component-based architecture for integrating SSI solutions into web applications. They highlight that SSI solutions are focused on fulfilling users' requirements. But to foster the adoption of decentralised IdM by users, there is an urgent need to facilitate the embracing of SSI principles by the service providers. Huang *et al.* [11] claim that while technological advances stimulate the need for new technologies, products and services, the trustworthiness of IdM systems is a critical factor in systems design.

3 RESEARCH METHOD

In this paper, we introduce an approach to analyse and assess identity management systems in the context of business operations and information systems. The proposed approach should guide organisations that are considering a transition towards decentralised IdM and help them make decisions about its utility based on the assessment results. During the first step, we propose to define what are the verifiable credentials, their purpose in the business operations, and how they support social dependencies. Second, we model the current IdM system implementations in the business context. Third, we design the DPKI-enabled IdM system to satisfy the purposes identified in the first step. The final step includes performing the evaluation of both IdM systems' quality in terms of trustworthiness. Following [11], we regard trustworthiness as the beliefs of the system users in expected attributes. Thus, being trustworthy for the IdM system means being able to enable social trust. For the evaluation, we propose to use the following quality criteria: (i) *security* - to which security attack the IdM system implementation is prone; (ii) *reliability* - how often the IdM system implementation causes downtimes or delays during the communication; (iii) *control* - how much control over the credentials the identity holder has. To assess those criteria, we propose to use the respective quality properties and measures from the assessment model presented in Fig. 1.

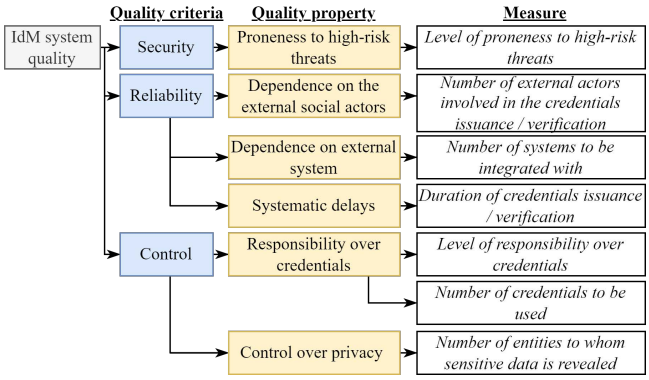


Figure 1: Identity management system quality assessment model

To assess the security of the IdM system, we propose to assess *proneness to high-risk threats*, which is measured by the subjective estimation of its level. The reliability of the system can be characterised by the next three properties: (i) *dependence on the external social actors* which characterises how much the system is self-sufficient and how many external factors can influence the system's reliability; to measure it we propose to count how many external actors participate in the credentials issuance/verification activities from which the number of assumptions and trust dependencies is put; (ii) *dependence on external systems* that characterise the complexity of the system itself, how many connection points between systems there are which potentially can cause delays or be bottlenecks, and finally (iii) *systematic delays* that describe the systematic waiting times caused by the system implementation specifics. The higher values of the mentioned security and control measures negatively affect the overall quality of the IdM system. To assess *control* we propose to look at how much *responsibility over credentials* an identity holder has and to which extent they are in *control over privacy*. To assess the level of responsibility, we suggest looking into which components of credentials (e.g., VC, keys) should be managed by the holder and to which extent, and how many credentials there are to be managed in such a manner. Finally, to assess the control over privacy we propose to consider the number of entities to whom sensitive data from VCs is revealed. The values of the control's measures may have either positive or negative effects on the overall IdM quality depending on the users' expectations and trust of the business to users' capabilities.

In the end, having the results of IdM systems assessments, we compare how well they are aligned with the business objectives, users' expectations from the system, and how well the depicted quality changes justify the shift towards the new IdM system.

4 X-ROAD CASE STUDY

For complex information systems which facilitate communication in the digital government infrastructure, the question of trust [15] is fundamental. Users of such systems (i.e. trustors) want the system to enable their social reliance on other users (i.e. trustees) who are expected to perform particular actions important to the trustors. To answer the stated RQ, we study how X-Road, which serves as the

backbone for several digital government infrastructures worldwide, supports the trust of its users through the identity management system and what effect the transition to decentralised IdM will have.

4.1 X-Road Description

X-Road is a centrally-managed distributed data exchange layer between information systems that provides a standardised and secure way to produce and consume services over the web within the trusted network [19].

From the organizational point of view, there are four key roles in the trusted network (see Fig. 2). *(X-Road) Governing Authority* is an organization that owns an instance and defines regulations and practices which must be followed in the ecosystem. *(X-Road) Operator* is an organization that manages an instance of the X-Road ecosystem. *(X-Road) Member* is an organization that can join the X-Road instance to provide and/or consume services by exchanging messages with other Members. *Trust Services Provider(s)* are organizations that are time-stamping authorities (TSA) and/or certification authorities (CA) that can be either third-party or owned by the Operator. To sum up, Members are key system users who choose to trust one another in providing services, while Operator and Trust Services Providers are actors who enable Members' social trust dependencies through the IdM system set up in X-Road.

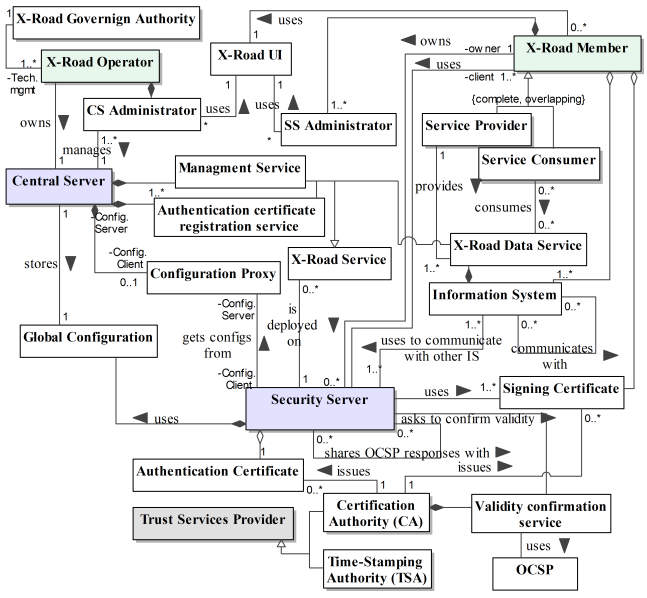


Figure 2: Entities in the X-Road ecosystem (green – network participants' roles; purple – core system components; grey – external trusted service providers)

The X-Road ecosystem consists of a trusted network of organisations that use the same instance of the software for providing and consuming services. The X-Road system has two main components - Central Server and Security Server. *Central Server* (CS) is managed by an Operator of the X-Road instance and is responsible for the registration of Members and their Security Servers' addition, authentication, and removal. *Security Server* (SS) is an entry point to X-Road which is managed by Members and mediates service calls and service responses between information systems of Members.

Two key identities managed by X-Road are Member and Security Server. Currently, the management of these identities relies on PKI X.509. To become a Member, an organization should have a *signing certificate* issued by one of the trusted CAs. Members may use a few SSs as a proxy (i.e. be a client of the SS). Each SS has its own *authentication certificate*. The Governing Authority defines the list of trusted third-party CAs. Alternatively, the Operator may play a role of a certification authority. The process of obtaining a signing or authentication certificate depends on the speed of processing certificate signing requests (CSR) by trusted CAs. This process varies for different CAs and may include several manual steps of checking the characteristics of the prospective Members, and it might require days, weeks or even months to be completed.

4.2 Case Study Design: Data Collection and Analysis Procedures

To address our main RQ, we follow the approach presented in Section 3 to analyse how the two identity management system implementations - based on the conventional PKI and decentralised PKI - support the trust and member management in the data exchange system. To this end, the case study aims to answer the three research sub-questions.

RQ_1: What are the trust dependencies of actors in the data exchange system and how are they supported by the system implementation? The research process starts with the analysis of the As-Is system (see Sec. 5.1). We define the aim of signing and authentication certificates in X-Road, the procedure of issuing signing and authentication certificates for Members, the onboarding process of a Member, and the trust model. The following inputs are used: (i) X-Road Academy courses [19], (ii) official documentation [17, 18], and (iii) expert opinion. To answer RQ1 we depict social dependencies in X-Road using the i*/Tropos framework [9] which defines trust requirements. Additionally, we use process modelling and class diagrams to define the system components that enable meeting trust requirements.

RQ_2: How can DPKI enable trust and member management in the data exchange system? In the next stage we design the analogue VCs and actors in the context of DPKI (see Sec. 5.2). This step results in the redefined trust model and identified actors, system functionalities, components, and processes that should be in place for identity management using DPKI in X-Road.

RQ_3: What is the difference between identity management systems trustworthiness and member management? We use the proposed assessment model to assess the identity management system (see Fig. 1).

5 ANALYSIS AND DESIGN RESULTS

5.1 Centralised Identity Management

5.1.1 VCs issuance and verification. There are two identities managed in X-Road - the identity of each Security Server and Members. A set of trusted CAs issues the credentials in a form of certificates which are used by the X-Road components to identify that the Member or SS is the one it claims to be.

For identification and verification of Members, the VC_{sign} credentials (i.e. *signing certificates*) are used. The VC_{sign} credentials

are issued to a Member (*holder* and *subject*) by one of the trusted CAs (*issuer*) with the claim "The Member *client_ID* has a valid signing key pair". These credentials VC_{sign} are used when the Member joins the X-Road instance, sets up a SS, or registers as a SS's client. CS plays the role of *verifier* by verifying the proof. After the onboarding process, VC_{sign} are verified by (Service Provider's) SS when the Member makes an X-Road request for the service. In such case, VC_{sign} are used to verify that the Member who initiates the request with the SS: (1) has a valid signing certificate issued by the trusted CA, (2) is a legitimate holder of the VC_{sign}, and (3) the provided signature value is correct.

The identity of Security Servers is managed using the VC_{auth} credentials (i.e. *authentication certificates*). The VC_{auth} are issued to SS (*holder* and *subject*) by the CA (*issuer*) with the claim "The Security Server *SecServer_ID* owned by the client *client_ID* has a valid authentication key pair". During the onboarding process, VC_{auth} are used when a SS is set up (Member provides proof of having VC_{auth} as a part of the authentication certificate registration request). CS plays the role of *verifier* by verifying the proof. Later on, after the onboarding process, VC_{auth} are verified by Service Provider's or Client's Security Server when the secure connection between parties is established. In such case, VC_{auth} are used to verify that the SS which initiates the connection with another SS: (1) has a valid authentication certificate issued by the trusted CA, (2) is a legitimate holder of the VC_{auth}, and (3) the provided certificate is an authentication certificate.

The current system analysis started with modelling the processes manipulating VCs. The business process of a new Member onboarding is modelled using Business Process Model and Notation (BPMN 2.0). Upon the conclusion of the legal agreement between the Governing Authority and the prospective Member, the Operator registers the Member in the system. The key part of a Member's onboarding is becoming a client of the SS that in the end allows the Member to provide/consume service via X-Road.

If the Member wants to use its own SS, first, the Member sets it up. For this, the signing key and corresponding certificate should be obtained for the Member; the authentication key and corresponding certificate should be obtained for the SS (the procedure of obtaining the authentication certificate is analogue to the sub-process 'Configure signing key and certificate'). Upon obtaining the certificates, they should be imported and activated in the SS. After obtaining the authentication certificate, the authentication certificate registration request (signed with the Member's signing key) is sent to the Central Server for approval. Once Central Server approves the request to register the SS, Members of the network can initiate registration as the SS's clients.

Fig. 3 depicts the configuration of a signing certificate. The process starts when the Member uses the SS UI (to which they have access as a Member of the network) to generate a signing key pair. The pair is saved as a PKCS #12 file. Based on this file, the Member applies for the certificate by sending a certificate signing request (CSR) following PKCS #10 format to the selected CA. Receiving the CSR, CA checks the request, conducts some manual checks of the applier's identity, and in the case of approval, CA generates the certificate for the provided authentication key pair. The certificate is stored in the certificate base to be accessed on-demand for verification. The credentials configuration happens off X-Road

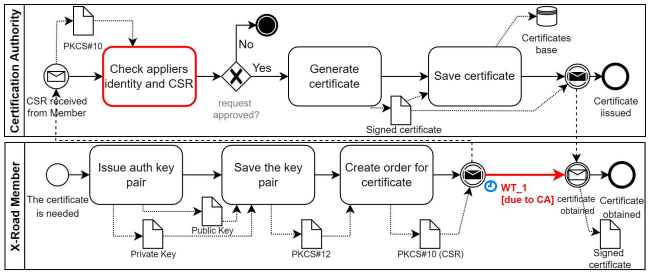


Figure 3: Credentials issuance using PKI

mostly manually. Exactly the mentioned manual check of the identity by CA causes waiting time during the Members' onboarding (see WT_1 in Fig. 3). While the X-Road Owner has no way to influence CA to reduce waiting time, we consider the shift to another IdM system where CA as a bottleneck is eliminated.

The configuration of signing and authentication certificates is essentially analogous. There are two peculiarities of the signing certificate configuration. First, the generation of a signing key pair may be outsourced to the CA. In this case, the signing key pair is stored in the HSM (hardware security module) device, and the SS administrator does not have to create it. Second, depending on the X-Road instance policy, the Operator may be an intermediary party between the Member and CA when the Member sends a CSR.

Regardless of the type of VC, the verification process is essentially the same, and it is shown in Fig. 4. When an identity holder (SS or Member) wants to exchange a message with a verifier (another SS or Member), the former sends the message signed using the private key corresponding to the credentials (e.g., authentication certificate) together with the VC's ID and the certificate itself. The verifier checks the credentials issued by the trusted CA and searches for information about the validity of the credentials (OCSP response) in the message. When issuing a connection between two SSs, In case of a missing OCSP response for VC_{auth}, the verifier requests it from the holder, who requests it from the certification authority that issued credentials. When it comes to VC_{sign}, the OCSP response is included in the message (request or response), and therefore, the verifier does not have to request it separately.

More details about the centralised identity management in X-Road can be found in our report [3].

5.1.2 Trust Model. To depict the trust in the current system where actor dependencies take a center stage, we need to scrutinise which goals, resources and/or tasks X-Road actors depend on one another. We use *the i*/Tropos* modelling framework to depict the mentioned social dependencies. In [9] authors illustrate how i* modelling supports the definition of social settings between relevant system stakeholders on which requirements to the IdM system are based. The current social dependencies enabled by PKI are depicted in Fig. 5. There are three main actors who depend on each other with some goals and trust.

X-Road Operator has a goal of *issuing certificates to Members* (both signing and authentication). X-Road Operator delegates meeting the goal (i.e. delegates its permission) to CA. So, X-Road Operator trusts the CA to meet this goal. Similarly, X-Road Operator trusts

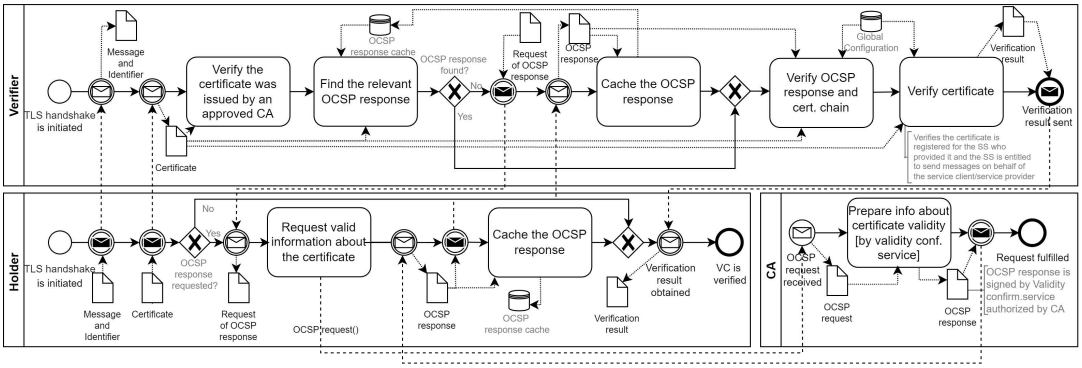


Figure 4: Credentials verification using PKI

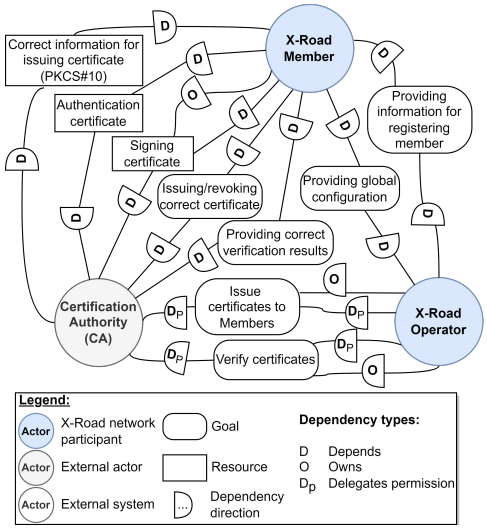


Figure 5: X-Road Trust Dependency Model: Context of PKI

the CA to meet the goal of *verifying certificates* (both signing and authentication). Meanwhile, the trust dependencies between Member and CA are tighter. Member depends on CA with *issuing/revoking a correct certificate*, providing *correct verification results*, providing a an *authentication certificate* to a Security Server owned by the Member, providing *signing certificate* for identifying Member's identity. In turn, CA trusts Member to provide *correct information for issuing a certificate*. Additionally, Member depends on X-Road Operator with the goal *providing global configuration* while X-Road Operator depends on a Member with the goal of *providing information for registering Member*. In summary, CA is a RoT, and X-Road ecosystem actors are highly dependent on it.

5.2 Decentralised Identity Management

Following the spirit of SSI, we introduce the decentralised public key infrastructure to the X-Road ecosystem. In this section, we describe how the DPKI can be integrated into the data exchange system and how the newly introduced credentials should be used by the Members and SSs to prove their identities. The proposed design assumes that both Member's and Security Server's identities shifts to the DID-based credentials.

5.2.1 Conceptual architecture. The conceptual architecture of the DPKI-based X-Road is depicted in Fig. 6. The components coloured in purple are part of the X-Road system, and the other black-coloured components are external entities. Here dApp corresponds to the decentralised application for the blockchain. The dApp should define rules for credentials validation. For this Zero-Knowledge proofs (ZKP) may be used for checking Member's attributes when issuing credentials, creating VP and its verification.

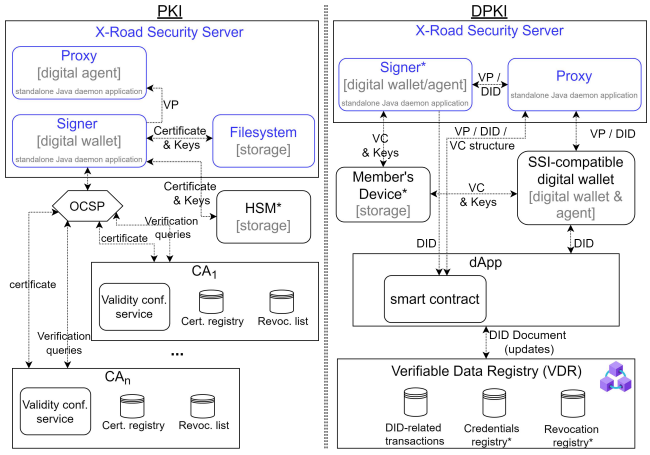


Figure 6: Conceptual architectures of the X-Road ecosystem

Let us start with the preliminary decisions the X-Road system owners should make. First, the owner should select the verifiable data registry (VDR) and the DID method to be used by Members for DID-related transactions. A decentralised application (dApp) for the selected registry is integrated, and its smart contracts enable issuance of the DIDs based on the provided VCs and proofs, call of DID resolver and access to the credential and revocation registries (if any). Second, the distributed IdM allows the Members to use an external SSI-compatible digital wallet as an alternative to the Signer component of the SS. Thus, the X-Road SS should enable integration with such SSI-compatible digital wallets. The Signer

component in the to-be system stores the credentials and key locally on the Member's device. Thereby, Members become in control of their identity. Thereby, the usage of the Online Certificate Status Protocol (OCSP) is eliminated.

Additionally, Governing Authority should decide whether to use VDR for maintaining credentials and revocation registries. A *credential registry* can be used for duplicating VCs issued to Member/SS (they contain the same claims as in the original VCs, but the holder is the Credentials registry instead of the subject itself). Such architecture makes the credential registry responsible for publishing the credentials so that they can be searched, discovered, and verified by any qualified verifier. If a credential registry is used, the issued DID-based VC_{sign} and VC_{auth} should not contain any claims or attributes to be classified as special category data under the GDPR terminology. If special category data should be a part of credentials or the VC's privacy want to be preserved, it can be either included in the encrypted format on-chain or stored off-chain. Similarly, a *revocation registry* may be used as an additional way to check the validity of the credentials by means of ZKP. The holder should create proof of non-revocation, and the verifier can check this proof against the revocation registry in VDR. If the VDR supports ZKP cryptography, the verifier can check only the revocation status of the presented proof without revealing any information about the credentials themselves.

The operation of decentralised identity management is possible under a few assumptions. Mostly the assumptions are related to the infrastructural settings and prerequisites for the stakeholders.

First, X-Road Governing Authority and Operator have DID-based credentials to be able to prove their identities to the prospective X-Road Members upon their onboarding to the X-Road instance. As a result, Members are sure they are connecting to the legitimate X-Road instance they concluded the agreement. Second, the distributed ledger to be used for the management of the DIDs for VCs should be SSI-compatible. Thus, the ledger should provide the mechanism and features for DIDs and functioning including DID resolver. Third, the trusted issuers of the authentication and signing credentials for the Members should have DID-based credentials in the trusted decentralised distributed ledger. Alternatively, self-certifying identifiers managed in the decentralised distributed ledger should be allowed eliminating the need for specialised trusted issuers. Forth, the Member should have the credentials required by issuers (for obtaining the authentication and signing credentials) in the DID-based format stored in any SSI-compatible digital wallet. Finally, the issuance of the authentication and signing of DID-based credentials is not facilitated by any means of X-Road.

The digital wallet provider should enable the decentralised key management system (DKMS). Thus, if the Member uses an external digital wallet, the key management for VC_{sign} and VC_{auth} should be conducted by the selected digital wallet. To enable the DKMS within the X-Road's digital wallet, first, the Signer component of each SS, which plays the role of a digital wallet, should store keys and credentials locally on the Member's device. Second, the Signer should enable the backup file and recovery keys. For this, the Signer must conduct an automatically encrypted backup copy of the wallet in the location of the Member's choice. In case of loss or corruption of the local device where the wallet stores credentials, the system

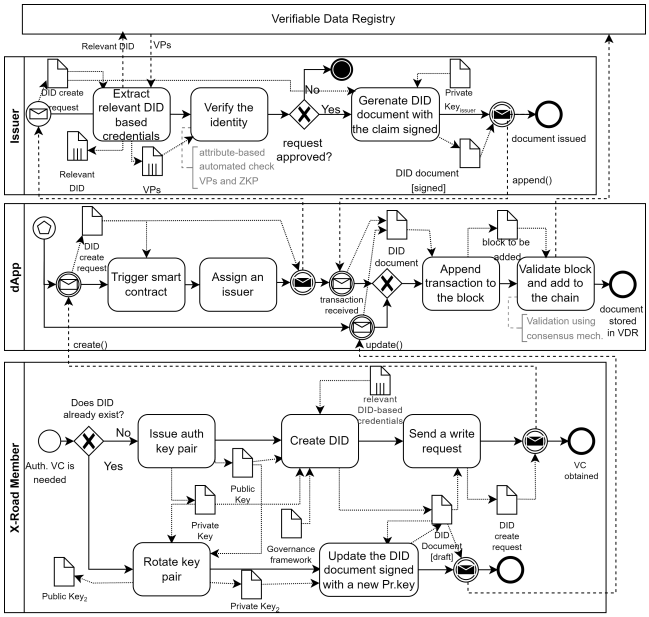


Figure 7: Credentials issuance in DPKI

should allow restoring the most recent state of the wallet from the backup copy using the recovery key. The recovery key can be stored (i) offline on the HSM or (ii) cryptographically split into N secret shares, which are provided to other (randomly selected) X-Road Members.

5.2.2 VCs issuance and verification. Fig. 7 and 8 depict the proposed processes of issuing and verifying credentials enabled by the DPKI. The signing certificate used as a VC for verifying the identity of a Member is changed to the DID document. The DID document should be generated based on the public and private signing key pair that is equivalent to the current signing certificate. However, the DID document should be generated within the selected distributed ledger network and stored in its ledger (i.e. verifiable data registry). There are a few options for the distributed ledger network: it can be explicitly created for X-Road, or the existing special-purpose SSI distributed ledger networks can be used (e.g., Sovrin, Veramo). The comparison of the state-of-the-art blockchain-based SSI solutions [21] shows that Sovrin [8, 24] and uPort are the solutions which are compliant with the most SSI principles compared to other existing solutions Also, the method for generating DID in the ledger can be selected from the set of existing methods [25] or explicitly created for X-Road. We argue that for the SSI implementation in the data exchange system used predominantly in the governmental sector, GA would prefer the SSI ecosystem based on the private blockchain or at least public permissioned. The reasons are that private blockchains are faster, while both private and permissioned give more control over the network participants [12]. Consequently, Sovrin or the X-Road-specific SSI ecosystem are recommended to be used.

Also, we propose the unification of the credentials storage. Currently, Member should have a separate VC_{sign} for each SS and store

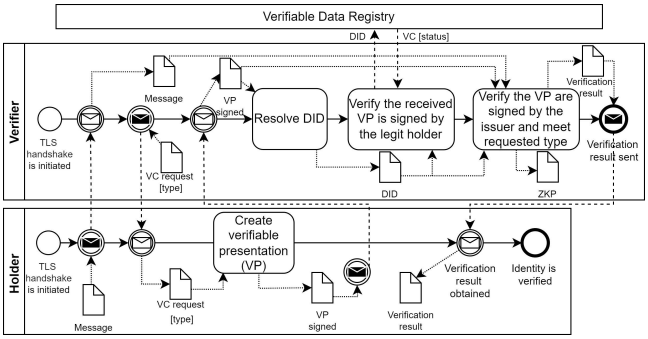


Figure 8: Credentials verification in DPKI

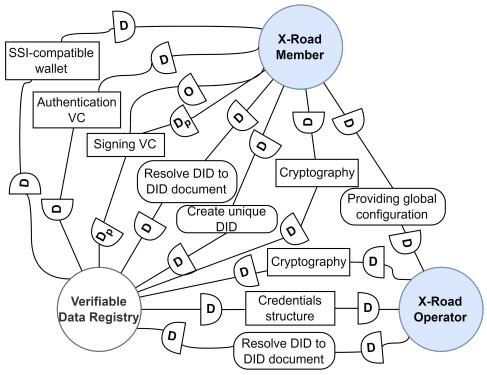


Figure 9: X-Road Trust Dependency Model: Context of DPKI

such VC_{sign} in SS's filesystem. We suggest that the Member should have one digital wallet to store all its VCs to use for the proof presentation for any verifier. As mentioned above, the Member can choose either an external SSI-compatible digital wallet that will be used or provided by X-Road. We propose to have one VC_{sign} per Member, so when the Member wants to prove the identity to another Member, Security Server requests the corresponding VP_{sign} from the global digital wallet.

5.2.3 Trust Model. Fig. 9 depicts the DPKI-enabled social trust between the X-Road network participants. The external system of the Verifiable Data Registry represents the distributed ledger network that enables decentralised storage and access to verifiable credentials.

Instead of trust to a centralised certification authority (in the case of PKI), the RoT in the DPKI shifts to the used distributed ledger (i.e. Verifiable Data Registry) and the cryptography on which the ledger is based.

5.3 Systems Assessment and Comparison

5.3.1 Assessment of PKI. To assess the level of system security, we use the following measurements scales: (0) low level – the system is vulnerable to a considerable number of security threats that threaten confidentiality, integrity and availability of business assets; (1) medium level – the system is vulnerable to the threat of medium probability which may have a significant influence on the business operations; (2) high level – the system is vulnerable only to the threats which are of low probability due to complexity of implementation. From a security point of view, the public key infrastructure is prone to a single point of failure. In case of compromising the root certification authority, the integrity, confidentiality and availability of the credentials are compromised, and the identity management system implementation becomes untrustworthy. Therefore, we assess the *security* level as medium level (1) (see Table 1).

Table 1: IdM systems assessment results

Quality Criteria	Quality Property	Measure	PKI	DPKI
Security	Proneness to high-risk threats	Level of proneness to high-risk threats	**1**	**1**
Reliability	Dependence on the external social actors	Number of actors involved (issuance / verification)	**1 / 2**	**1 / 0**
	Dependence on external system	Number of systems to be integrated with (issuance/ verification)	**0 / N**	**1..2 / 1..2**
	Systematic delays	Time of credentials issuance / verification	**hrs.. mths/ secs**[1]	**secs / secs**[2]
Control	Responsibility over credentials	Level of responsibility over credentials	**0**	**2**
		Number of credentials to be used	**K + M**	**1 + K**
	Control over privacy	Number of entities to who sensitive data is revealed (issuance / verification)	**1 / 1**	**0..1/ 0..1**

The main weakness of the current system is its reliability. The third-party CA checks the applicant's identity, which may include a manual check of the organisation's characteristics. Stakeholders highlight that such an identity check (for some CAs) causes waiting time from hours to months (see Fig. 3, Table 1) during the new Member's onboarding. As a result, prospective Members experience delays at the beginning of the X-Road system usage as they cannot provide/consume services through the data exchange system. Due to the same reason, Members may experience downtimes when their certificates expire, but members forget to renew them beforehand. In terms of dependency on the external system, the number of systems to be integrated with for the issuance of the credential is equal to one, as the Member submits the application manually. A verifier relies on the OCSP caching managed by the Member (identity holder) using the CA's validity confirmation system for credentials verification. The OCSP caching system highly faults tolerant and very configurable [13]; however, Members should establish connections with services of all the CAs they have credentials from (see Fig. 3, where N – the number of CAs). As a result, the integration of Members' Security Servers with the CAs' validity confirmation services through the usage of OCSP and sharing the cached results of credentials verification between SSs provide a high level of system accessibility during the credentials usage.

Finally, we consider how much control an identity holder has over its data. To assess the level of system responsibility over credentials, we use the following measurements scales: (0) low level – the system is fully responsible for and has access to all the user's

[1] according to https://www.digicert.com
[2] assuming usage of Hyperledger with 3,000 TPS https://doi.org/10.1002/nem.2099

Table 2: Data disclosure analysis in X-Road (data artefact visibility is described by the following levels: V - visible, O - owner, H - hidden)

Conventional PKI							Decentralised PKI							
Issuance														
	Sensitive info	Public Key	Private Key	PKCS #12	PKCS #10 (CSR)	Certificate		Public Key	Private Key	DID document	Relevant DIDs	Relevant DID-based credentials	VP	Sensitive info
Member (Holder)	O	O	O	O	O	V	Member (Holder)	O	O	O	O	O	-	O
CA	V	V	-	-	V	O	Verifiable Data Registry	V	-	V	V	V	O	V
							Issuer	V	-	V	V	H	V	H
Verification														
	OCSP response cache	OCSP response	Certificate					VC	VP	DID	Sensitive info			
Verifier	V	V	V				Verifier	-	V	V	H			
Member (Holder)	V	V	O				Member (Holder)	O	O	-	O			
CA (OCSP Service)	-	O	V				Verifiable Data Registry	V	-	V	V			

identity data (including all the identity's attributes, credentials and keys); (1) medium level – the system is responsible for and has access to the predefined identity's attributes and may control the keys; (2) high level – a user may choose to which credentials and their presentations the system has access to; and the user is responsible for managing keys. In terms of control over the keys, PKI may allow Members to recover the lost private keys (if the service provider generated them), giving the Members some flexibility and the right to make mistakes, sacrificing some control over their identity. As a result, we assess the level of *control* as low (0). In the meantime, a Member should have a separate signing certificate for each Security Server they manage (the number of signing certificates per Member is referred to as K in Table 1) and additionally manage authentication certificates of the owned SSs (number of the owned SSs referred to as M in Table. 1).

To evaluate how much privacy control the Member has over their identity, we evaluated the data artefacts' visibility to the participants of the collaboration. The visibility is evaluated using the data disclosure analysis in [6]. The results (see Table 2) illustrate that the usage of PKI and certificates implies that whatever information is mentioned in the credentials (certificate), such information is accessible to the issuer and verifier, and the identity holder cannot control the verifiable presentation of credentials.

5.3.2 Assessment of DPKI. To assess the designed DPKI in X-Road, we use the presented earlier models and the surveys of the building blocks of the DPKI [2, 16, 20, 21, 23]. Thereby, we conduct a theoretical assessment of the X-Road system design before the actual implementation of the system prototype.

The decentralisation of credentials and the root of trust allows us to eliminate a single point of failure in X-Road. However, the DPKI-based X-Road system becomes vulnerable to threats specific to distributed ledgers (e.g., consensus mechanism attacks). Thereby, the *security* of the system is at a medium level (1).

Following the made assumptions, the initial identities check, and decision about the issuance of the DID-based credentials should be conducted based on the attributes of other SSI-compatible VCs. As a result, waiting time in the current system implementation caused by the manual identity check is eliminated, and the Members' onboarding process is speeded up. As DIDs are unique within the DID method namespace, there is no need to check their uniqueness to allow the holder to use them. In essence, the issuance of the credentials and the update of expired credentials are automated. To issue the credentials, one network participant (external actor) should act as an issuer. And for the credentials verification, the verifier does not rely on any external actor as they can access the registry to check the status of the credentials. The systematic delays during the credentials issuance/verification correspond to the time of appending/retrieving transactions from the VDR. Assuming, VDR is based on the Hyperledger, both operations should be done in seconds. Lastly, in terms of dependency on the external systems, only integration with dApp is mandatory while the usage of an external digital agent is an option if X-Road provides the analogue functionality.

Finally, the shift to the DPKI enables identities to have more control over their data. Moving to the DLT allows for preserving the holder' privacy because instead of creating public VCs signed by the issuer, which later is to be presented to a verifier, a zero-knowledge verifiable claim is issued to the holder who provides zero-knowledge proofs to the verifier. Thereby, reliance on DPKI gives the Member to control the data disclosure level depending on whether Member relies on the attributed-based check enabled by ZKP from the existing DID-based credentials and their verifiable presentations (see Table 2). Such privacy preservation is delivered, for example, by the Sovrin ledger [8].

To answer RQ_3, we highlight the following potential improvements enabled by migration to DPKI. First, the distribution of the credentials database supports the elimination of a single point of failure. Second, thanks to the uniqueness of DIDs within the DID method namespace and the automation of identity checks based on the SSI-compatible credentials, there is an expected speed-up in obtaining credentials and, consequently, the member onboarding process. Additionally, a holder can use a DID immediately after the rotation of the public key as no new certificate should be issued by CA. A new DID document is signed with the previous private key; there is a chain of DID documents signed by its holder. Finally, the credentials verification is expected to be done faster. Blockchain has low latency for the read operation (e.g., the credentials and proof extraction), and cryptography should boost verification of the validity of the credentials (through smart contracts and ZKP). To sum up, the shift to the DPKI for managing identities within the X-Road ecosystem is expected to increase the trustworthiness of the data exchange system by increasing the level of system reliability and control.

6 DISCUSSION

Our research approach to the identity management system analysis and the case study rests upon multifaceted process modelling, the state-of-the-art concept of self-sovereign identity, contributing to the research of how social trust is supported by the IdM system implementations [1, 7, 10]. While the SSI landscape is fragmented and the way of its implementation in real-world running systems is not clearly defined [10], the service providers are shifting to the decentralisation of trust. To this end, this paper proposed an approach of the initial enterprise system analysis, which should guide the service providers on how to move toward embracing SSI.

In contrast to [14], we believe that during the transition to a new social trust model, the IS component which supports the social trust on the technical implementation level, namely the identity management system, should be assessed on its support of the expected trust dependencies. Such support refers to the trustworthiness of the IdM system. Therefore, the paper proposed a model for assessing the IdM system that should help define changes to expect in the dimensions of security, reliability and user control during the transition between IdM systems.

Furthermore, we highlight the supportive role of enterprise modelling during the IdM system analysis. While the change in the trust model concerns multiple aspects of the business operations and information system, the changes should also be depicted from multiple dimensions. Similarly to [7], we used BPMN to illustrate the provided problem statement at the business process level. The UML class diagram describes the system architecture and depicts how system components, roles, and data objects are connected. While there is no standardised way to depict the trust model [7, 14], we found the *i*/Tropos* framework [9] useful for defining the system stakeholders' social trust dependencies supported by the system components.

7 CONCLUSION

To sum up, this paper introduced the approach to analysing and assessing identity management systems in the context of business operations and information systems. The research method followed in this paper should guide the organisations through the process of their identity management system redesign in order to justify (or decline) the shift towards SSI implementation based on the assessment results. The validation has been done through the case study of the X-Road ecosystem. We have shown how the shift towards a self-sovereign identity concept may affect the data exchange system – X-Road. The proposed system design is based on the transition to the decentralised identity management system by means of DPKI. The comparison of the currently used IdM and the proposed design confirmed that members' onboarding process could be speeded up thanks to the elimination of manual identity verification. Further, the analysis of alternative system designs from the perspective of trustworthiness found that some designs were more trustworthy than others. The decentralised root of trust enabled by DPKI may help to improve system reliability as it enables the automated issuance and verification of credentials and the elimination of some dependencies on external systems and actors. DPKI gives users have more control over their identity by letting them manage keys and credentials, which, on the other hand, poses higher responsibility in terms of technical preparedness and managing DID-based credentials. The ease of meeting prerequisites for a new system may vary depending on the industry, the specifics of the system, and the number of current system users.

Our work is limited to a theoretical validation through assessment of the enterprise system. We now develop a proof-of-concept prototype to apply the proposed identity management infrastructure in the X-Road system. The prototype assessment will allow us to strengthen the estimation of the system's trustworthiness. The future work potentially will extend the analysis approach with extra steps for decisions on the selection of distributed ledger for the verifiable data registry.

REFERENCES

[1] European Union Agency for Cybersecurity , Evgenia Nikolouzou, Viktor Paggio, and Marnix Dekker. 2022. *Digital Identity: Leveraging the SSI Concept to Build Trust.* Publications Office of the European Union. https://doi.org/10.2824/8646

[2] Christopher Allen, Arthur Brock, Vitalik Buterin, Jon Callas, Duke Dorje, et al. 2015. *Decentralized public key infrastructure. A White Paper from Rebooting the Web of Trust.* Technical Report.

[3] Mariia Bakhtina, Raimundas Matulevičius, Ahmed Awad, and Petteri Kivimäki. 2022. *Rebooting Trust Management in X-Road.* Public Report. Nordic Institute for Interoperability Solutions (NIIS).

[4] Sharon Boeyen, Stefan Santesson, Tim Polk, Russ Housley, Stephen Farrell, and David Cooper. 2008. Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile. RFC 5280. https://doi.org/10.17487/RFC5280

[5] Kim Cameron. 2005. The laws of identity. *Microsoft Corp* 12 (2005), 8–11.

[6] Marlon Dumas, Luciano García-Bañuelos, Joosep Jääger, Peeter Laud, Raimundas Matulevičius, Alisa Pankova, et al. 2021. Multi-level privacy analysis of business processes: the PLEAK toolset. *International Journal on Software Tools for Technology Transfer* 24, 2 (2021), 1–21.

[7] Walid Fdhila, Nicholas Stifter, and Aljosha Judmayer. 2022. Challenges and Opportunities of Blockchain for Auditable Processes in the Healthcare Sector. In *BPM 2022 Blockchain, RPA and CEE Forum*. Springer International Publishing, Cham, 68–83.

[8] Sovrin Foundation. 2018. *Sovrin: A Protocol and Token for Self-Sovereign Identity and Decentralized Trust.* White Paper.

[9] Paolo Giorgini, Fabio Massacci, John Mylopoulos, and Nicola Zannone. 2006. Requirements engineering for trust management: model, methodology, and reasoning. *International Journal of Information Security* 5, 4 (2006), 257–274.

[10] Andreas Grüner, Alexander Mühle, and Christoph Meinel. 2019. An Integration Architecture to Enable Service Providers for Self-sovereign Identity. In *NCA*. IEEE, 1–5. https://doi.org/10.1109/NCA.2019.8935015

[11] Jingwei Huang, Mamadou D. Seck, and Adrian Gheorghe. 2016. Towards trustworthy smart cyber-physical-social systems in the era of Internet of Things. In *SoSE*. IEEE, 1–6. https://doi.org/10.1109/SYSOSE.2016.7542961

[12] Georgy Ishmaev. 2021. Sovereignty, privacy, and ethics in blockchain-based identity management systems. *Ethics Inf. Technol.* 23, 3 (2021), 239–252.

[13] Petteri Kivimäki. 2020. Resisting Failure. https://www.niis.org/blog/2020/11/20/resisting-failure.

[14] Jianwei Liu, Adam Hodges, Lucas Clay, and John Monarch. 2020. An analysis of digital identity management systems-a two-mapping view. In *BRAINS*. IEEE, 92–96.

[15] Roger C. Mayer, James H. Davis, and F. David Schoorman. 1995. An Integrative Model of Organizational Trust. *The Academy of Management Review* 20, 3 (1995), 709–734. http://www.jstor.org/stable/258792

[16] Alexander Mühle, Andreas Grüner, Tatiana Gayvoronskaya, and Christoph Meinel. 2018. A survey on essential components of a self-sovereign identity. *Computer Science Review* 30 (2018), 80–86. https://doi.org/10.1016/j.cosrev.2018.10.002

[17] Nordic Institute for Interoperability Solutions (NIIS). [n. d.]. X-Road Documentation. https://github.com/nordic-institute/X-Road/tree/develop/doc.

[18] Nordic Institute for Interoperability Solutions (NIIS). [n. d.]. X-Road Resources. https://x-road.global/xroad-library.

[19] Nordic Institute for Interoperability Solutions (NIIS). 2020. X-Road Academy. https://x-road.thinkific.com/.

[20] Alex Preukschat and Drummond Reed. 2021. *Self-sovereign identity.* Manning Publications, Shelter Island, NY.

[21] Mohammed Shuaib, Noor Hafizah Hassan, Sahnius Usman, Shadab Alam, Surbhi Bhatia, et al. 2022. Self-Sovereign Identity Solution for Blockchain-Based Land Registry System: A Comparison. *Mobile Information Systems* 2022 (2022), 1–17. https://doi.org/10.1155/2022/8930472

[22] Adam J. Slagell and Rafael Bonilla. 2004. PKI Scalability Issues. *CoRR* cs.CR/0409018 (2004), 1–23.

[23] Reza Soltani, Uyen Trang Nguyen, and Aijun An. 2021. A survey of self-sovereign identity ecosystem. *Security and Communication Networks* 2021 (2021), 8873429:1–8873429:26. https://doi.org/10.1155/2021/8873429

[24] Andrew Tobin. 2018. *Sovrin: What Goes on the Ledger?* White Paper. Evernym.

[25] World Wide Web Consortium (W3C). 2022. Peer DID Method Specification. https://www.w3.org/TR/did-spec-registries/#did-methods.

[26] World Wide Web Consortium (W3C). 2022. Verifiable Credentials Data Model v1.1. https://www.w3.org/TR/vc-data-model.